

Service Misconfigurations

Misconfigurations usually happen when a system administrator, technical support, or developer does not follow the framework of an application, website, desktop, or server leading to dangerous open pathways for unauthorized access. In this section, we will look at some of the most typical misconfigurations of common services.

Authentication

In previous years (though we still see this sometimes during assessments), it was widespread for services to have default credentials (username and password). This presents a security issue because many administrators leave the default credentials unchanged. Nowadays, most software asks users to set up credentials upon installation, which is better than default credentials. However, keep in mind that we will still find vendors using default credentials, especially on older applications.

Even when the service does not have a set of default credentials, an administrator may use weak passwords when setting up services with the idea that they will change the password once the service is set up and running.

As administrators, we need to define password policies that apply to software tested or installed in our environment. These policies should be required to comply with a minimum password complexity to avoid user and password combinations that are easy to guess.

Service Misconfigurations

```
admin:admin  
admin:password  
admin:<blank>  
root:12345678  
administrator:Password
```

Once we grab the service banner, the next step should be to identify possible default credentials. If there are no default credentials, we can try the weak username and password combinations listed above.

Anonymous Authentication

Another misconfiguration that can exist in common services is anonymous authentication. The service can be configured to allow anonymous access, which is a security risk.

The initial configuration of devices and software may include but is not limited to settings, features, files, and values are usually aimed at usability rather than security. Leaving it default is not a good security practice. Unnecessary defaults are those settings we need to change to secure a system by reducing its attack surface.

We might as well deliver up our company's personal information on a silver platter if we take the easy road while setting up software or a device for the first time. In reality, attackers may obtain access credentials for a weak setting by conducting a short internet search.

[Security Misconfiguration](#) are part of the [OWASP Top 10 list](#). Let's take a look at those related to default values.

- Unnecessary features are enabled or installed (e.g., unnecessary ports, services, and privileges).
- Default accounts and their passwords are still enabled and unchanged.
- Error handling reveals stack traces or other overly informative error messages.
- For upgraded systems, the latest security features are disabled or not configured.

Preventing Misconfiguration

Once we have figured out our environment, the most straightforward strategy to control risk is to lock down the system and only allow desired behavior. Any communication that is not required by the program should be disabled.

- Admin interfaces should be disabled.
- Debugging is turned off.
- Disable the use of default usernames and passwords.
- Set up the server to prevent unauthorized access, directory listing, and other common attacks.
- Run scans and audits regularly to help discover future misconfigurations or misconfigurations.

The OWASP Top 10 provides a section on how to secure the installation processes:

- A repeatable hardening process makes it fast and easy to deploy another environment that is appropriate for development, QA, and production environments should all be configured identically, with different configurations for each environment. In addition, this process should be automated to minimize the effort required to set up a new environment.
- A minimal platform without unnecessary features, components, documentation, and samples. Remove unnecessary features and frameworks.

Table of Contents

Introduction

Interacting with Common Services

Protocol Specific Attacks

The Concept of Attacks

[Service Misconfigurations](#)

Finding Sensitive Information

FTP

 Attacking FTP

Latest FTP Vulnerabilities

SMB

 Attacking SMB

Latest SMB Vulnerabilities

SQL Databases

 Attacking SQL Databases

Latest SQL Vulnerabilities

RDP

 Attacking RDP

Latest RDP Vulnerabilities

DNS

 Attacking DNS

Latest DNS Vulnerabilities

SMTP

 Attacking Email Services

Latest Email Service Vulnerabilities

https://academy